



File No.: EXP202309952

RESOLUTION OF FILE OF PROCEEDINGS

From the proceedings carried out by the Spanish Agency for Data Protection and based on the following

FACTS

FIRST: On May 25, 2023, a complaint was filed with registration number REGAGE23e00033334938 before the Spanish Agency for Data Protection, which highlights a possible infringement attributable to MEDANO4YOU, S.L. (hereinafter, MEDANO). The reasons for the complaint are as follows:

The complainant made a reservation for the accommodation "(...) - by MEDANO4YOU" through booking.com. On 29/03/2023, she received WhatsApp messages from a British mobile number, in which someone, allegedly on behalf of the accommodation and knowing her personal data (name, email address, phone number, reservation number, and reserved accommodation), contacted her. She received a first welcome message and a second message informing her of a supposed incident regarding the reservation, asking her to confirm the payment details by accessing an email that contained a link that turned out to be fraudulent.

The complainant contacted MEDANO, responsible for the accommodation. Through the messaging service of Booking.com, MEDANO indicated that a fraud threat had been detected, warned her not to provide her data if she received a message through Booking.com, and provided her with an alternative contact phone number. On 09/04/2023, the complainant filed a report regarding the events with the National Police. Along with the notification, fraudulent WhatsApp messages, a message from MEDANO alerting about the fraud, and the National Police report No. ***REFERENCE.1 with the complaint were submitted.

SECOND: In accordance with Article 65.4 of Organic Law 3/2018, of December 5, on Personal Data Protection and the guarantee of digital rights (hereinafter LOPDGDD), the complaint was forwarded to MEDANO for analysis and to inform this Agency within one month of the actions taken to comply with the requirements set forth in data protection regulations.

The transfer, which was carried out in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), was made via electronic notification, which was made available on 14/07/2023 and accepted on 17/07/2023. No response was received to this transfer notification.

THIRD: On 25/08/2023, in accordance with Article 65 of the LOPDGDD, the complaint was admitted for processing.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

2/7

FOURTH: The General Subdirectorate for Data Inspection proceeded to carry out preliminary investigation actions to clarify the facts in question, by virtue of the functions assigned to control authorities in Article 57.1 and the powers granted in Article 58.1 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and in accordance with the provisions of Title VII, Chapter I, Section two, of the LOPDGDD, being aware of the following points:

Requested to report on the operation of reservations, MEDANO stated the following:

"Medano4you, S.L., is a company dedicated to managing properties of many owners and exploiting the rental and vacation tourism of the same. People who want to stay in the properties they manage can reserve through different means, Booking, Airbnb, or their own platform medano4you.com.

(...)

The data is processed by Booking.com, as indicated, and transmitted to the establishment via a message with certain data, but not all. Booking is the main data controller. The establishment will

receive all the necessary data from the guest at the time of check-in.”

Regarding the transfer of information between Booking.com and the accommodation, according to the statements provided, the operational work would consist of using third-party management software, KROSS BOOKING, which connects to third-party services, such as Booking.com, and processes and transfers the information so that it can be attended to by the establishment's staff. Additionally, the accommodation receives an email with the reservation details. Regarding the use of the management software that acts as an intermediary between the Booking.com platform and local devices, MEDANO states that it is an automatic process and provides documentation on privacy management in this tool. This processing by the establishment would be carried out outside the environment of the Booking.com platform, as stated by the responding party: “They are stored on their own servers that have not been threatened by the incident, nor by any other.” Additionally, locally stored spreadsheets on the accommodation's devices would be used: “what is stored on the computers is the transcription of that software via spreadsheets.”

On the other hand, the responding party states the following about the use they make of the Booking.com platform:

“Three computers are used to access Booking, only three, precisely because according to the administrator it is very difficult to pair a new computer. On the other hand, they only access Booking to download invoices from the platform and to register a new property. In day-to-day operations, they do not access the account, as they do not need it for the exercise of daily functions.”

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
3/7

In any case, even if the party being claimed does not access Booking.com directly, it is independent of whether new customer bookings can be received through that platform and whether data is dumped using the management software.

In the context of the preliminary investigation proceedings, information has been requested from BOOKING.COM, B.V. (hereinafter, BOOKING), through the Dutch Data Protection Authority.

According to BOOKING (the response is translated):

“A single account can only view the reservations of the accommodations that the account has access to. This means that the account cannot be used to view reservations made by a customer at accommodations not linked to the account. Furthermore, through a single account, only the details of a single guest's reservation can be viewed using the search functionality for reservations belonging to the accommodations that the account has access to, and only for non-archived reservations. An accommodation provider cannot choose a guest and view their reservation history in an aggregated manner or in any other way.”

Based on this, a potential security breach affecting an accommodation would be limited to the scope of that establishment and the platform, and could not be caused by a third accommodation unrelated to the platform.

MEDANO informs that the incident and fraud against the claiming party is framed within a security breach that affected more customers, who received scam attempts similar to the one reported. While in the reported case the fraudulent communication was made using WhatsApp and email, in other cases the messaging system of the BOOKING platform was used and provides as evidence of this fact various messages, similar to that of the claim, using the platform.

MEDANO claims to be unaware of the scope and origin and points to the Booking.com platform as responsible for the security incident.

For its part, BOOKING states that it has no record of the accounts used by MEDANO being compromised in 2023. It reports that it has identified that using the accounts of other accommodations there were similar fraud attempts and shifts the possible responsibility onto the accommodations, indicating as a possible cause the accounts of these and the computer systems under the control of the platform users (the accommodations).

In the course of the preliminary investigation proceedings, it has not been possible to determine the

origin of the breach.

Regarding the impact of the breach, according to the information provided by MEDANO, it would amount to 24 individuals, taking as a reference the number of customers who were contacted through the messaging system of the Booking.com platform and to whom MEDANO had access. Once the incident was known, MEDANO informed the possible affected parties (customers who had booked their accommodations). It provides examples of the communications made.

Regarding the communications maintained between MEDANO and BOOKING in relation to the incident, the former states the following:

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

4/7

“On March 30, 2023, and subsequent days, an email was sent to the assigned sales representative, but as there was no response, the incident was managed by phone. Therefore, there is no evidence to provide.”

Regarding the security measures adopted before the breach, (...).

LEGAL GROUNDS

I

Competence

According to the functions conferred to each supervisory authority by Article 57.1 a), f) and h) of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR) and as provided in Articles 47 and 48.1 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and Guarantee of Digital Rights (hereinafter LOPDGDD), the Presidency of the Spanish Data Protection Agency is competent to resolve these investigation proceedings.

Furthermore, Article 63.2 of the LOPDGDD states: “The procedures processed by the Spanish Data Protection Agency shall be governed by the provisions of Regulation (EU) 2016/679, this organic law, the regulatory provisions issued for its development, and, as long as they do not contradict them, subsidiarily by the general rules on administrative procedures.”

II

Preliminary Issues

Article 4, paragraph 12 of the GDPR broadly defines “personal data security breaches” (hereinafter security breach) as “all breaches of security that result in the accidental or unlawful destruction, loss, alteration of, or unauthorized communication or access to personal data transmitted, stored, or otherwise processed.”

In the present case, there is a personal data security breach under the circumstances indicated above, categorized as a confidentiality breach, as a third party had access to the claimant's data and used it to commit fraud.

It should be noted that the identification of a security breach does not imply the direct imposition of a sanction by this Agency, as it is necessary to analyze the diligence of those responsible and the security measures applied.

Within the principles of processing provided in Article 5 of the GDPR, the integrity and confidentiality of personal data is guaranteed in paragraph 1.f) of Article 5 of the GDPR. Meanwhile, the security of personal data is regulated in Articles 32, 33, and 34 of the GDPR, which govern the security of the

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

5/7

treatment, the notification of a personal data security breach to the supervisory authority, as well as the communication to the affected party, respectively.

III

Presumption of Innocence

In this case, a complaint was filed due to the compromise of the confidentiality of personal data related to the reservation of accommodation, which allegedly resulted in an attempted fraud.

From the investigative actions carried out by this Agency, as outlined in the background, it has not been possible to determine the origin of the breach. Furthermore, there has been no evidence of a lack of security measures on the part of MEDANO from which responsibility for the origin of that breach could be concluded.

In this regard, it should be emphasized that in the field of administrative sanctions, the principles inspiring criminal law apply, with some nuances but without exceptions, having full effect the principle of presumption of innocence, which must govern without exceptions in the sanctioning legal framework and must be respected in the imposition of any sanctions.

The Constitutional Court in Judgment 76/1990 considers that the right to the presumption of innocence entails “that the sanction is based on acts or incriminating evidence of the reproached conduct; that the burden of proof lies with the accuser, without anyone being obliged to prove their own innocence; and that any insufficiency in the results of the evidence presented, freely assessed by the sanctioning body, must result in an acquittal.”

In accordance with this approach, Article 53.2 of the LPACAP establishes that, in the case of administrative procedures of a sanctioning nature, the alleged responsible parties shall have the following rights:

“a) (...)

b) The presumption of non-existence of administrative responsibility until proven otherwise.”

As the Supreme Court clarified in its Judgment of October 26, 1998, the validity of the principle of presumption of innocence

“does not oppose that judicial conviction in a process may be formed on the basis of circumstantial evidence, but for this evidence to undermine said presumption, it must satisfy the following constitutional requirements: the indications must be fully proven – they cannot be mere suspicions – and the reasoning by which, based on the proven indications, it has been concluded that the accused committed the infringing conduct must be explicit, since otherwise, neither the subsumption would be grounded in law nor would there be a way to determine whether the deductive process is arbitrary, irrational, or absurd, that is, whether the right to the presumption of innocence has been violated by considering that the evidentiary activity can be understood as incriminating.”

Thus, it is necessary to distinguish true circumstantial evidence from mere suspicions or conjectures.

The Constitutional Court has stated in its Judgment 24/1997 that

“the criteria for distinguishing between circumstantial evidence capable of undermining the presumption of innocence and mere suspicions are based on the following: a) The circumstantial evidence must stem from fully proven facts. b) The facts constituting the crime must be deduced from those indications (fully proven facts) through a reasoned mental process in accordance with the rules of human reasoning, as stated in the convicting judgment (SSTC 174/1985, 175/1985, 229/1988, 107/1989, 384/1993, and 206/1994, among others).”

In summary, the principle of presumption of innocence prevents attributing an administrative infringement when no incriminating evidence has been obtained and verified that substantiates the facts motivating the accusation or the involvement of the alleged infringer in them.

In this case, as stated, there are no rational indications that would allow attributing to the accused party the commission of infringements of personal data protection regulations, so the right to the presumption of innocence that protects them cannot be considered undermined.

IV

Conclusions

Therefore, based on the aforementioned paragraphs, no evidence has been found that substantiates the existence of an infringement within the jurisdiction of the Spanish Agency for Data Protection.

All of this is without prejudice to any subsequent actions that this Agency may carry out, applying the investigative and corrective powers it holds.

Thus, as it has not been possible to attribute responsibility for the origin of the breach, in accordance with what has been indicated, by the Presidency of the Spanish Agency for Data Protection,

IT IS AGREED:

FIRST: TO ARCHIVE the present proceedings

SECOND: TO NOTIFY this resolution to MEDANO4YOU, S.L. and to the complainant.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

7/7

In accordance with the provisions established in Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure as provided by Article 114.1.c) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations, and in accordance with the provisions established in Articles 112 and 123 of the aforementioned Law 39/2015, of October 1, the interested parties may optionally file a motion for reconsideration before the Presidency of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and Section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law.

1245-240125

Lorenzo Cotino Hueso

President of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es